# ZAP by Checkmarx Scanning Report

Generated with ZAP on Sat 28 Mar 2026, at 16:08:39

ZAP Version: 2.17.0

ZAP by Checkmarx

## Contents


- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=`Medium`, Confidence=`Medium` (1)
  - Risk=`Low`, Confidence=`High` (1)
  - Risk=`Low`, Confidence=`Medium` (2)

- Risk=Informational, Confidence=Medium (1)
- Risk=Informational, Confidence=Low (1)
- Appendix
  - Alert Types


# About This Report

## Report Parameters

### Contexts

No contexts were selected, so all contexts were included by default.

### Sites

The following sites were included:

- https://demo.openmrs.org

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

### Risk levels

Included: High, Medium, Low, Informational

Excluded: None

### Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

# Summaries

## Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

| | | Confidence | | | | |
|---|---|---|---|---|---|---|
| | | User Confirmed | High | Medium | Low | Total |
| Risk | High | 0 (0.0%) | 0 (0.0%) | 0 (0.0%) | 0 (0.0%) | 0 (0.0%) |
| | Medium | 0 (0.0%) | 0 (0.0%) | 1 (16.7%) | 0 (0.0%) | 1 (16.7%) |
| | Low | 0 (0.0%) | 1 (16.7%) | 2 (33.3%) | 0 (0.0%) | 3 (50.0%) |
| | Informational | 0 (0.0%) | 0 (0.0%) | 1 (16.7%) | 1 (16.7%) | 2 (33.3%) |
| | Total | 0 (0.0%) | 1 (16.7%) | 4 (66.7%) | 1 (16.7%) | 6 (100%) |

## Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

| | | Risk | | | |
|---|---|---|---|---|---|
| | | High (= High) | Medium (>= Medium) | Low (>= Low) | Informational (>= Informational) |
| Site | https://demo.openmrs.org | 0 (0) | 1 (1) | 3 (4) | 2 (6) |

## Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

| Alert type | Risk | Count |
|---|---|---|
| Spring Actuator Information Leak | Medium | 1 (16.7%) |
| Cookie Without Secure Flag | Low | 1 (16.7%) |
| Cookie without SameSite Attribute | Low | 1 (16.7%) |
| Total | | 6 |

| Alert type | Risk | Count |
|---|---|---|
| Server Leaks Version Information via "Server" HTTP Response Header Field | Low | 3 (50.0%) |
| Re-examine Cache-control Directives | Informational | 1 (16.7%) |
| Session Management Response Identified | Informational | 1 (16.7%) |
| Total | | 6 |

## Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

| Level | Reason | Site | Description | Statistic |
|---|---|---|---|---|
| Low | Warning | | ZAP errors logged - see the zap.log file for details | 2 |
| Low | Warning | | ZAP warnings logged - see the zap.log file for details | 3 |
| Info | Informational | https://demo.openmrs.org | Percentage of responses with status code 2xx | 18 % |
| Info | Informational | https://demo.openmrs.org | Percentage of responses with status code 3xx | 69 % |

| Level | Reason | Site | Description | Statistic |
|---|---|---|---|---|
| Info | Informational | https://demo.openmrs.org | Percentage of responses with status code 4xx | 11 % |
| Info | Informational | https://demo.openmrs.org | Percentage of endpoints with content type application/json | 50 % |
| Info | Informational | https://demo.openmrs.org | Percentage of endpoints with content type text/html | 50 % |
| Info | Informational | https://demo.openmrs.org | Percentage of endpoints with method GET | 100 % |
| Info | Informational | https://demo.openmrs.org | Count of total endpoints | 4 |
| Info | Informational | https://demo.openmrs.org | Percentage of slow responses | 2 % |

# Alerts

### Risk=`Medium`, Confidence=`Medium` (1)

#### https://demo.openmrs.org (1)

### Spring Actuator Information Leak (1)

▶ GET https://demo.openmrs.org/openmrs/ws/rest/actuator/health

## Risk=Low, Confidence=High (1)

#### https://demo.openmrs.org (1)

### Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▶ GET https://demo.openmrs.org/sitemap.xml

## Risk=Low, Confidence=Medium (2)

#### https://demo.openmrs.org (2)

### Cookie Without Secure Flag (1)

▶ GET https://demo.openmrs.org/openmrs/ws/rest/v1

### Cookie without SameSite Attribute (1)

▶ GET https://demo.openmrs.org/openmrs/ws/rest/v1

## Risk=Informational, Confidence=Medium (1)

#### https://demo.openmrs.org (1)

### Session Management Response Identified (1)

▶ GET https://demo.openmrs.org/openmrs/ws/rest/v1

### Risk=Informational, Confidence=Low (1)

#### https://demo.openmrs.org (1)

#### Re-examine Cache-control Directives (1)

▶ GET https://demo.openmrs.org/openmrs/ws/rest/v1

# Appendix

## Alert Types

This section contains additional information on the types of alerts in the report.

### Spring Actuator Information Leak

| | |
|---|---|
| **Source** | raised by an active scanner (Spring Actuator Information Leak) |
| **CWE ID** | 215 |
| **WASC ID** | 13 |
| **Reference** | ▪ https://docs.spring.io/spring-boot/api/rest/actuator/index.html#overview |

### Cookie Without Secure Flag

| | |
|---|---|
| **Source** | raised by a passive scanner (Cookie Without Secure Flag) |

| | |
|---|---|
| **CWE ID** | 614 |
| **WASC ID** | 13 |
| **Reference** | ▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html |

### Cookie without SameSite Attribute

| | |
|---|---|
| **Source** | raised by a passive scanner (Cookie without SameSite Attribute) |
| **CWE ID** | 1275 |
| **WASC ID** | 13 |
| **Reference** | ▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site |

### Server Leaks Version Information via "Server" HTTP Response Header Field

| | |
|---|---|
| **Source** | raised by a passive scanner (HTTP Server Response Header) |
| **CWE ID** | 497 |
| **WASC ID** | 13 |
| **Reference** | ▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens<br>▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) |

- https://www.troyhunt.com/shhh-dont-let-your-response-headers/

### Re-examine Cache-control Directives

**Source** raised by a passive scanner (Re-examine Cache-control Directives)

**CWE ID** 525

**WASC ID** 13

**Reference**

- https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control
- https://grayduck.mn/2021/09/13/cache-control-recommendations/

### Session Management Response Identified

**Source** raised by a passive scanner (Session Management Response Identified)

**Reference**

- https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/